

Scope Description

Working Title

Agentic LLM-Based Vulnerability-Oriented Test Generation for REST APIs

Project type: Master thesis

Problem statement

Modern Large Language Models (LLMs) have become more and more capable of generating high-quality unit and integration tests. However, they still struggle to reason about authorization logic that spans multiple users, object ownership, and resource lifecycle states. As a result, vulnerabilities such as Broken Object Level Authorization (BOLA), also known as Insecure Direct Object References (IDOR), remain among the most common security flaws in REST APIs.

This leads to the following research question:

Can an agentic LLM autonomously generate and execute multi-step, multi-identity test scenarios that discover object-level authorization vulnerabilities in REST APIs more effectively than existing automated testing approaches?

Why is this relevant?

REST API's are the backbone of modern web applications, cloud services, and mobile applications. Ensuring that authorization is correctly enforced is therefore very important. According to the OWASP API Security Top 10, BOLA is consistently ranked as the number 1 most critical API security vulnerability. (<https://owasp.org/www-project-api-security/>)

Current automated testing techniques mainly rely on rule-based scanners or coverage-oriented API fuzzers. While these approaches are effective for discovering implementation bugs or increasing API coverage, they generally lack an understanding of ownership and authorization semantics. Likewise, current agentic coding assistants such as Claude Code and GitHub Copilot focus primarily on generating functional tests rather than reasoning about security scenarios involving multiple users.

This research aims to bridge that gap by combining OpenAPI specification analysis with agentic AI. Instead of executing isolated requests, the proposed system will reason about sequences of API interactions involving multiple identities and object states to uncover authorization flaws. Besides contributing to software testing research, such a system could assist developers in finding security vulnerabilities earlier during development while producing reproducible and explainable test cases.

Why am I the one to solve it?

Throughout my studies I have developed an interest in cybersecurity, software testing, and AI. I have practical experience developing REST APIs and software systems, which allows me to understand both the implementation and testing perspectives.

In addition, my academic background has provided me with knowledge of software testing, software quality, and machine learning techniques. This combination makes me well suited to investigate how agentic LLMs can be applied to automated security testing.

The project also aligns with the expertise of the AnSyMo research group, allowing me to build upon existing research on REST API testing and OpenAPI-based test generation and also extending it towards vulnerability-oriented testing.

Proposed approach

The project will investigate whether an autonomous LLM agent can generate security-focused test cases from an OpenAPI specification.

The first step is to analyze the API specification to identify resources, relationships, and ownership information. This will be stored in the agent's context window.

The core of the system will be an agentic LLM planner that generates sequences of API requests. Rather than testing single endpoints independently, the planner will reason about object creation, ownership transfer, lifecycle changes, and access attempts performed by different users.

The generated requests will then be executed against the target API, after which the responses will be analyzed to detect potential authorization violations.

Finally, any discovered vulnerabilities will be translated into reproducible test cases together with a natural-language explanation describing why the behavior indicates a possible security issue.

The effectiveness of the approach will be evaluated using intentionally vulnerable benchmark REST APIs and compared against existing rule-based scanners, REST API fuzzers, and general-purpose coding agents.

Rough planning

The project will start with a literature review on REST API testing, authorization vulnerabilities, and agentic LLMs.

After defining the research scope, the initial implementation will focus on parsing OpenAPI specifications and automatically creating multiple test identities.

The second phase will concentrate on designing and implementing the LLM-based planning agent capable of generating multi-step authorization tests. Subsequently, the execution framework and vulnerability detection mechanism will be developed.

The final stage of the project will consist of an empirical evaluation against existing approaches, analysis of the obtained results, and finalizing the master's thesis report.